



Can general purpose
LLMs do level 1 Triage?

Rômulo Rocha

PEAK DEFENSE:
BUILDING ADAPTIVE SYSTEMS
FOR MODERN THREATS



\$whoami

- Rômulo Rocha
- I'm from Brazil. Rio de Janeiro. **BRBR**
- I did this research on my “free time”, thanks to my spouse and my kids for their support.
- I've been in Security for around 18 years.
- This is my second FIRST (lol) talk, I'm much more nervous.
- I'm skeptical to magical solutions.
- I'm just a curious guy, I'm not a mathematician, not a machine learning specialist, I'm not a scientist. Be kind. =)



[Linkedin.com/in/romrocha](https://www.linkedin.com/in/romrocha)

Agenda

- Why this research?
- Agent architecture (stack, 101, details, some printscreens)
- Research (Dataset, Plan, Hypothesis, Fine-tuning & Training approach)
- Results (Campaign recall, metrics, cost, latency,etc)
- Conclusions (Insights and future work)

Why this research?

SOC Under Pressure : facing growth of alert volumes, overlapping detections, and persistent false positives. More than 80% of alerts may ultimately prove benign, making scale-through-headcount increasingly difficult, costly, and prone to analyst burnout and turnover.

Lack of Public Measurement : The term “*AI-Powered SOC*” is common, but public performance data remains scarce. Most decisions rely on closed proof of concept evaluations that are often constrained by limited time, datasets, or technical scope.

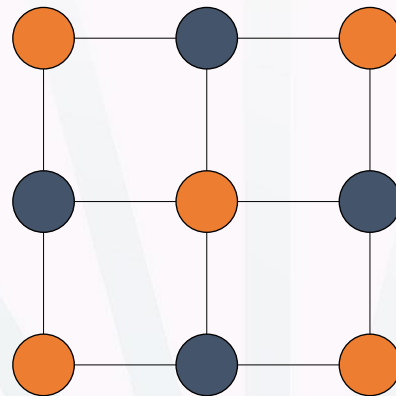
Maturing Agentic Architectures : Agent development frameworks have rapidly matured, providing observability, customization, orchestration, and extensive documentation that make practical experimentation increasingly feasible.

New Capabilities Enabled by LLMs and RAG: Modern AI systems introduce capabilities such as semantic correlation through embeddings, evidence-based reasoning, larger context windows, and retrieval-augmented workflows.

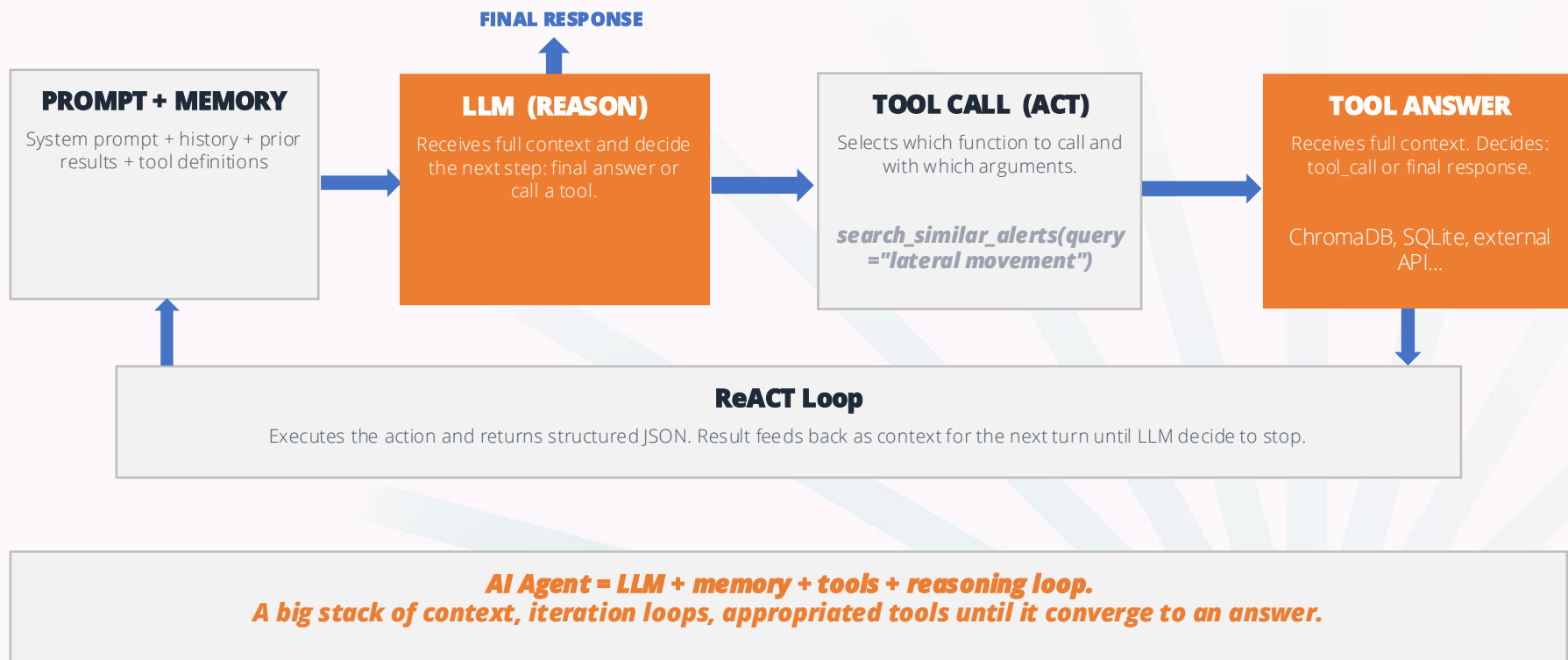
Reasoning Models vs. Standard Models: Since the introduction of reasoning-oriented models in 2025, a question emerged: *Are reasoning models inherently better suited for SOC Triage tasks than standard models?*

Agent Architecture

How it works, what is code and what is LLM,
engineering challenges.



Agent in a nutshell



Agent Stack

LangGraph

Agent Orchestration

ChromaDB

Vector store +
MiniLM-L6-v2

SQLite

Persisted State

LangSmith

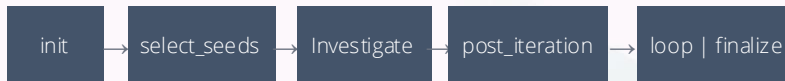
Observability

OpenAI

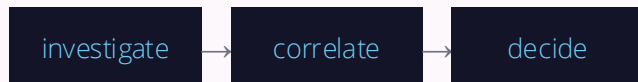
gpt-4.1-mini / gpt-5-mini

Graph

OUTER GRAPH (ROUND)



INNER GRAPH (One Investigation)



↻ edge condicional (recursion_limit=50)

Every node = `create_react_agent` (LangGraph canonical approach)

Triage Analyst Nodes

select_seeds

=

Queue Scan + Prioritization

investigate

=

Open an get alert context

correlate

=

Pivot between observables,
check temporal proximity, etc

decide

=

Register a campaign, mark false
positive or loop.

Human workflow mapped to agentic nodes

Agent details

Deterministic (Agent code)

- State graph (LangGraph) — Node order, transitions, exit conditions
- Guardrails & limits — max_loops, recursion_limit, retry guard, clamp
- Tool routing & execution
- Vector search & ingestion — ChromaDB query, chunking, embedding
- Persistence & state — SQLite thread-local, checkpointing, state schema
- Output parsing & validation — Structured output, confidence clamp, sanity checks

Non-Deterministic (LLM context)

- Alert triage & classification — Decide TP/FP, severity, confidence level
- Semantic correlation — Group alerts by narrative, not just IOC
- Tool selection decision — Tool_call and model choice via ReAct
- Reasoning & justification — 'Why is this alert a True Positive?' — free-form text
- Context interpretation (RAG) — What to do with chunks returned from vector store
- MITRE ATT&CK attribution — Map observed behavior to technique/tactic



Some runs have been hidden. [Show 337 hidden runs](#)

compute_time_delta

Called

2 other tools >

Input

System You are a Level-1 SOC analyst. You received an investigation summary. Decide whether the cluster has enough evidence to triage, or whether more investigation is needed. Tools available: - validate...

User

Assess the cluster from the investigation below — does the evidence support a coherent incident, or do the alerts look unrelated?

OPEN CASES (campaigns from earlier investigations)

Previously created campaigns. If you suspect overlap with any of these, fetch_campaign_alerts(campaign_id) returns the full alerts inside, and add_alerts_to_campaign lets you merge when overlap is confirmed:

- campaign-ransomware-finance-b-smith-2024-11 | 15 alerts | confidence=95% | Confirmed multi-stage intrusion campaign involving user b.smith and hosts FIN-LT-204 and FIN-WS-118 with credential thef alert_ids: [a1f2e8d4-9c3b-4a1e-8f7d-1a2b3c4d5e6f, a3b4e0c6-2c5b-6a3e-0d9c-3a4b5c6d7e8f, b2e3f9d5-1d4c-5b2f-9e8d-2b3c4d5e6f7a, b4c5f1d7-3d6c-7b4f-1e0d-4b5c6d7e8f9a, b8c9f5d1-7d0c-1b8f-5e4d-8b9c0d1e2f3a, ... (15 total)]
- campaign-case-d-araujo-2024-12 | 2 alerts | confidence=85% | Cluster of alerts for user d.araujo involving suspicious sign-ins from a Tor exit node IP address. alert_ids: [n4b5c6d7-e8f9-a0b1-c2d3-e4f5a6b7c8d0, n9c0d1e2-f3a4-b5c6-d7e8-f9a0b1c2d3e5]
- campaign-insider-exfil-hr-h-potter-2024-11 | 3 alerts | confidence=90% | Potential data exfiltration campaign involving user h.potter and HR-LT-118 endpoint with suspicious sign-ins and Dropbox alert_ids: [1a2b3c4d-5e6f-7a8b-9c0d-1e2f3a4b5c6d, 4b5c6d7e-8f9a-0b1c-2d3e-4f5a6b7c8d9e, 5e6f7a8b-9c0d-1e2f-3a4b-5c6d7e8f9a0b]

Investigation Summary (loop 1)

I investigated the two seed alerts and searched for related alerts by their usernames and hostnames.

- Alert n5c6d7e8-f9a0-b1c2-d3e4-f5a6b7c8d9e0 (PowerShell process started with hidden window) shares the username svc_itops and hostname OPS-WS-301. No other alerts were found with these observables.
- Alert n7e8f9a0-b1c2-d3e4-f5a6-b7c8d9e0f1a2 (PowerShell launched by uncommon parent process) shares the username svc_sccm and hostname FIN-WS-042. Another alert n2f3a4b5-c6d7-e8f9-a0b1-c2d3e4f5a6b7 with the same username and hostname was found. This alert involves PowerShell with encoded command argument by user a.ferreira on the same host. Both alerts are unprocessed and not linked to any campaign.
- A semantic search for similar alerts to "PowerShell process started with hidden window" returned several alerts including n4b5c6d7-e8f9-a0b1-c2d3-e4f5a6b7c8d9, which describes PowerShell launching from a non-standard directory by user svc_tanium on host ENG-LT-223. No other alerts share this username.
- None of the investigated alerts overlap with the previously known campaigns.

Summary: The seed alerts are part of a small cluster of PowerShell-related alerts involving service accounts svc_itops, svc_sccm, and svc_tanium on different hosts. One alert cluster involves svc_sccm on FIN-WS-042 with two related alerts. The other alerts appear isolated with no direct links to existing campaigns or other alerts. Further monitoring of these service accounts and hosts is recommended.

Alert IDs discovered (10 alerts)

["n5c6d7e8-f9a0-b1c2-d3e4-f5a6b7c8d9e0", "n7e8f9a0-b1c2-d3e4-f5a6-b7c8d9e0f1a2", "ba46e48e-b60b-5c79-a311-1d0bb2c5241a", "d4e5b1f7-3f6e-7d4b-1a0f-4d5e6f7a8b9c", "n2f3a4b5-c6d7-e8f9-a0b1-c2d3e4f5a6b7", "n3a4b5c6-d7e8-f9a0-b1c2-d3e4f5a6b7c8", "n4b5c6d7-e8f9-a0b1-c2d3-e4f5a6b7c8d9", "n5e6f7a8-b9c0-d1e2-f3a4-b5c6d7e8f9a2", "n6f7a8b9-c0d1-e2f3-a4b5-c6d7e8f9a0b3", "n8b9c0d1-e2f3-a4b5-c6d7-e8f9a0b1c2d5"]

Report example

CAMPAIGN #6: campaign-ransomware-h-potter-2024-12

Overview:

- Alerts: 16
- Confidence: 95.00%
- Summary: Confirmed correlated incident: targeted HR data exfiltration by h.potter from HR-LT-118 (USB + personal cloud + personal email). Recommend immediate escalation to IR/Insider Risk for containment (disable account, isolate host), preservation of forensics (host image, USB serial, archives, logs), and cloud/email provider coordination.
- Run ID: round3_no_ioc-gpt-5-mini-20260516T1637
- Created at: 2026-05-16 16:44:12

Alerts In This Case (chronological):

- 1a2b3c4d-5e6f-7a8b-9c0d-1e2f3a4b5c6d | Unusual after-hours sign-in to HR applications | source=Microsoft Entra ID Protection | date=2024-12-06T20:03:03Z | status=in_campaign
- 2b3c4d5e-6f7a-8b9c-0d1e-2f3a4b5c6d7e | Mass download from HR compensation site | source=Microsoft Defender for Cloud Apps | date=2024-12-13T02:38:29Z | status=in_campaign
- 3c4d5e6f-7a8b-9c0d-1e2f-3a4b5c6d7e8f | Anomalous file compression activity in user profile | source=Microsoft Defender for Endpoint | date=2024-12-24T22:41:46Z | status=in_campaign
- 4d5e6f7a-8b9c-0d1e-2f3a-4b5c6d7e8f9a | Removable storage device connected to managed endpoint | source=Microsoft Defender for Endpoint | date=2025-01-05T19:21:31Z | status=in_campaign
- 5e6f7a8b-9c0d-1e2f-3a4b-5c6d7e8f9a0b | Outbound TLS upload to dropbox.com from HR endpoint | source=Netskope | date=2025-01-12T18:52:23Z | status=in_campaign
- 6f7a8b9c-0d1e-2f3a-4b5c-6d7e8f9a0b1c | Large outbound transfer to personal cloud storage | source=Cisco Secure Firewall | date=2025-01-24T23:14:15Z | status=in_campaign
- n8b9c0d1-e2f3-a4b5-c6d7-e8f9a0b1c2d5 | WMI process creation on remote host | source=Microsoft Defender for Endpoint | date=2025-01-29T10:31:54Z | status=in_campaign
- round3_no_ioc/round3_no_ioc_results_gpt-4.1- | Sensitivity-labeled file accessed outside business pattern | source=Microsoft Purview | date=2025-02-03T14:05:20Z | status=in_campaign
- 8b9c0d1e-2f3a-4b5c-6d7e-8f9a0b1c2d3e | DLP policy match on outbound file containing HR salary taxonomy | source=Microsoft Purview | date=2025-02-17T00:57:24Z | status=in_campaign
- 9c0d1e2f-3a4b-5c6d-7e8f-9a0b1c2d3e4f | Salary workbook sent to personal webmail draft | source=Microsoft Purview | date=2025-03-07T10:11:20Z | status=in_campaign
- 0d1e2f3a-4b5c-6d7e-8f9a-0b1c2d3e4f5a | Repeated download of compensation exports | source=Microsoft Defender for Cloud Apps | date=2025-03-20T05:45:15Z | status=in_campaign
- 1e2f3a4b-5c6d-7e8f-9a0b-1c2d3e4f5a6b | Connection to personal cloud storage upload endpoint | source=Zscaler Internet Access | date=2025-04-01T16:18:01Z | status=in_campaign
- 2f3a4b5c-6d7e-8f9a-0b1c-2d3e4f5a6b7c | Password-protected multi-volume archive created | source=Microsoft Defender for Endpoint | date=2025-04-19T07:05:20Z | status=in_campaign
- 3a4b5c6d-7e8f-9a0b-1c2d-3e4f5a6b7c8d | High-volume data transfer to removable storage | source=Microsoft Purview | date=2025-05-01T08:43:02Z | status=in_campaign
- 4b5c6d7e-8f9a-0b1c-2d3e-4f5a6b7c8d9e | Outbound multi-part TLS to content.dropboxapi.com | source=Netskope | date=2025-05-14T08:14:05Z | status=in_campaign
- 5c6d7e8f-9a0b-1c2d-3e4f-5a6b7c8d9e0f | Microsoft Purview DLP - high-confidence salary keyword match in outbound message | source=Microsoft Purview | date=2025-05-22T23:28:27Z | status=in_campaign

Rationale:

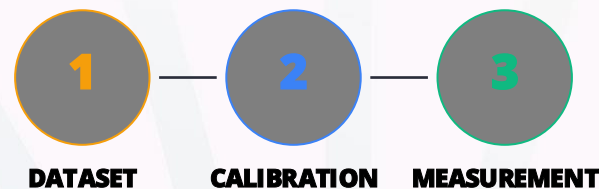
Strong, multi-telemetry correlation across identity, endpoint, DLP, cloud, and network showing the same user (h.potter) and host (HR-LT-118) performing targeted HR data collection and exfiltration (bulk SharePoint downloads, local passworded archives, USB writes, multi-part uploads to Dropbox endpoints and an outbound email to a personal Proton address). Timeline spans 167 days with repeated escalation in exfiltration behavior. No overlap with known ransomware campaign. High confidence this is an insider risk or compromised HR account requiring IR/Insider Risk escalation.

Logging actions

```
68 13:42:32 INFO =====
69 13:42:32 INFO Investigation 3 | seeds: 5c6d7e8f-9a0 | run_id=round3_no_ioc-gpt-5-mini-20260516T1637
70 13:42:32 INFO [investigate] Enter | loop=0 | seeds=5c6d7e8f-9a0
71 13:42:35 INFO [investigate] search_alerts_by_entity(type=?, value=?) -> 9 results
72 13:42:36 INFO [investigate] search_alerts_by_entity(type=?, value=?) -> 10 results
73 13:42:58 INFO [investigate] search_alerts_by_entity(type=?, value=?) -> 1 results
74 13:43:03 INFO [investigate] search_alerts_by_entity(type=?, value=?) -> 1 results
75 13:43:06 INFO [investigate] search_alerts_by_entity(type=?, value=?) -> 1 results
76 13:43:09 INFO [investigate] search_alerts_by_entity(type=?, value=?) -> 1 results
77 13:43:12 INFO [investigate] search_alerts_by_entity(type=?, value=?) -> 1 results
78 13:43:26 INFO [correlate] Enter | loop=1
79 13:43:39 INFO [correlate] compute_time_delta -> span=? days
80 13:43:39 INFO [correlate] validate_shared_entities -> 0 shared entities
81 13:43:49 INFO [correlate] ready_to_decide ->
82 13:43:52 INFO [route] correlate -> decide (ready_to_decide)
83 13:43:52 INFO [decide] Enter
84 13:44:12 INFO [decide] create_campaign(0 alerts) ->
85 13:44:30 INFO Investigation 3 done | 117.6s | 0 FP + 14 campaign | action=?
86 13:44:30 INFO [select_seeds] Enter | 32 already associated
87 13:44:31 INFO [select_seeds] list_unprocessed_summary ->
88 13:44:36 INFO [select_seeds] find_similar_cluster ->
89 13:44:44 INFO [select_seeds] submit_selected_seeds ->
90 13:44:48 INFO [select_seeds] Selected 1 seeds: 9c0d1e2f-3a4
```

Research

Dataset, fine-tuning, pre-experiment and time vector.



Dataset

- **SYNTHETIC DATASET (JSON):** Ensures reproducibility, controlled ground truth, zero PII exposure, and strict variable isolation between rounds — at the cost of reduced adversarial realism.
- **DELIBERATELY WEAK IOC ENRICHMENT:** Hostnames and usernames are the only recurring IOCs across campaigns. All other indicators (IPs, domains, URLs, files, hashes) appear once, requiring correlation via host, user, narrative, and semantic context.
- **REALISM AND STRUCTURAL VALIDATION:** Public detection repositories (Sigma, Atomic Red Team) informed alert design. Coverage spans 12 vendors, 47 MITRE ATT&CK techniques, 215 observables, and 76 IOCs.
- **100 ALERTS PER ROUND:** 70 false positives, 15 ransomware, 15 insider-threat. Sources include EDR, IdP, Email Gateway, DLP, proxy, and scanner telemetry, with intentional MITRE ATT&CK overlap.
- **THEHIVE SCHEMA:** Structured after TheHive's open-source SOC schema, with fields such as TLP, Flag, Status, SourceRef, and standard observable types.



More details and dataset: github.com/romrocha/research_dataset_2026

Experiment plan

Malicious Campaigning:

- **LockBit-Style Ransomware Campaign** — A ransomware intrusion beginning with a phishing email targeting user **b.smith** (T1566), followed by credential access (T1078, T1003.001), SMB-based lateral movement (T1021), and ransomware deployment on a file server (T1486).
- **HR Sensitive Information Exfiltration** — An insider threat scenario in which user **h.potter** on host HR-LT-118 accesses compensation data outside business hours (T1078, T1213), archives and exfiltrates sensitive HR information through Dropbox and USB devices (T1560, T1567, T1052).
- **Temporal Vector:**



Same composition, only time changes.

Hypothesis

“As the temporal window expands, temporal anchors become weaker, forcing the agent to rely increasingly on semantic signals and shared observables for correlation. If performance remains stable despite this loss of temporal proximity, it suggests the presence of semantic correlation rather than simple time-based association.”

Fine tuning – pre experiment

- More than 10 calibration rounds were conducted before comparative benchmarking.
 - Architectural improvements significantly impacted performance, **increasing accuracy by 9 percentage points while reducing missed threats by 66%**.
- The calibration process relied on trace analysis in LangSmith, assisted by an AI review agent.
- Tool interfaces were strongly typed using Pydantic, with validated schemas and structured outputs that stabilized the agent's decision-making process.
- Additionally, preloading prior decisions into the prompt improved consistency and reduced investigation time.

Total fine tuning cost ~ \$15 cost

The experiment!

- A total of 600 alerts were evaluated across 3 rounds of 200 alerts each.
- The experiment used the same canonical dataset, architecture, and toolset throughout; only the LLM (GPT-4.1-mini vs. GPT-5-mini) and the temporal window varied between rounds.
- The system was fully instrumented with LangSmith, enabling detailed auditing of token usage, iterations, tool calls, node latency, and operational cost.
- The pipeline was fully reproducible end-to-end, from dataset generation and execution notebooks to report creation and ground-truth comparison.
- Performance was measured using accuracy, F1 score (campaign detection and noise filtering), missed threats, latency, cost, and the Cost-Weighted Triage Score (CWTS).

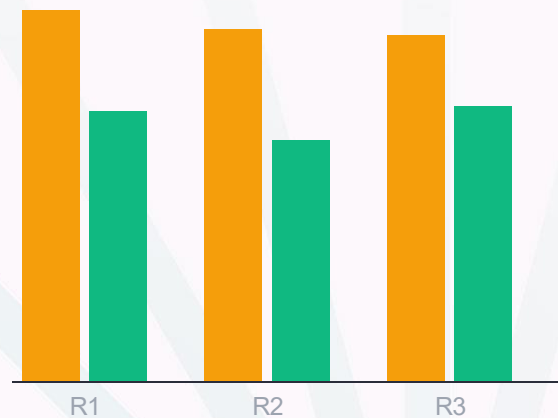
Total experiment cost: ~ \$6 USD

Early insights before experiment

- The project invested approximately three times more effort and cost into calibration than into benchmarking itself. In real-world SOC environments, both calibration and measurement must be continuous processes rather than one-time activities.
- Observability proved to be a critical enabler for agent improvement. Detailed traces, metrics, and execution visibility were essential for identifying failure modes, validating architectural decisions, and improving overall performance.
- At scale, trace volume quickly becomes overwhelming for manual review. Connecting an AI agent to the LangSmith MCP significantly accelerated the analysis of traces and the identification of optimization opportunities, substantially increasing the speed of agent iteration and improvement.

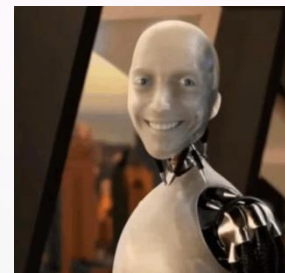
Results

Cost, latency and results data.



Yes, it works!

Both models detected the 2 real campaigns across all 3 rounds.



CAMPAIGN A — Finance Ransomware

b.smith · FIN-LT-204 · LockBit-style

Initial Access T1566	Credential Access T1003.001	Lateral Movement T1021	Impact T1486
--------------------------------	---------------------------------------	----------------------------------	------------------------

CAMPAIGN B — HR Insider Exfiltration

h.potter · HR-LT-118 · Dropbox+ USB

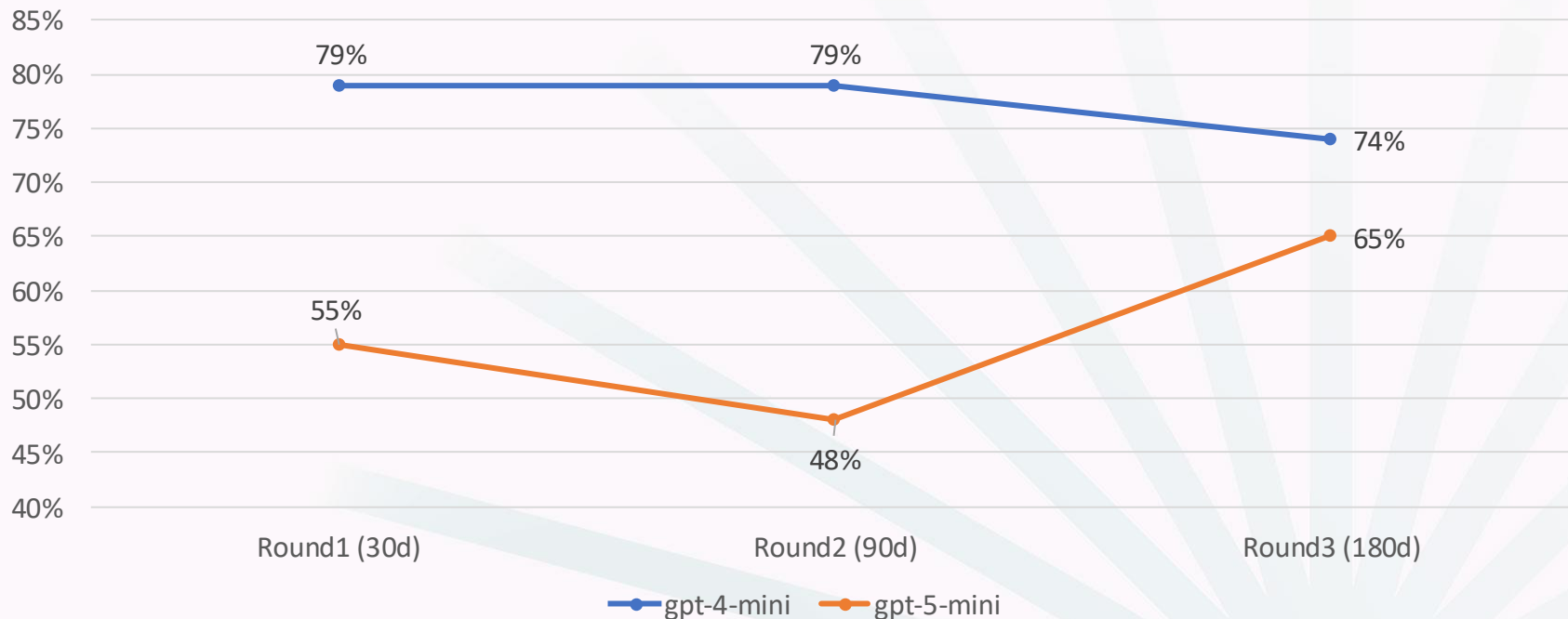
Initial Access T1078	Collection T1213	Staging T1560	Exfiltration T1567
--------------------------------	----------------------------	-------------------------	------------------------------

	R1 (30d)	R2 (90d)	R3 (180d)
	✓ DETECTED	✓ DETECTED	✓ DETECTED
4.1-mini	Recall: 15/15 Purity: clean cluster	Recall: 13/15 Purity: +2 extras	Recall: 11/15 Purity: +4 extras
5-mini	Recall: 15/15 Purity: +8 extras	Recall: 15/15 Purity: +10 extras	Recall: 15/15 Purity: +4 extras
	✓ DETECTED	✓ DETECTED	✓ DETECTED
4.1-mini	Recall: 15/15 Purity: clean cluster	Recall: 13/15 Purity: +1 extra	Recall: 11/15 Purity: +4 extras
5-mini	Recall: 15/15 Purity: +8 extras	Recall: 15/15 Purity: +12 extras	Recall: 15/15 Purity: +0 extras

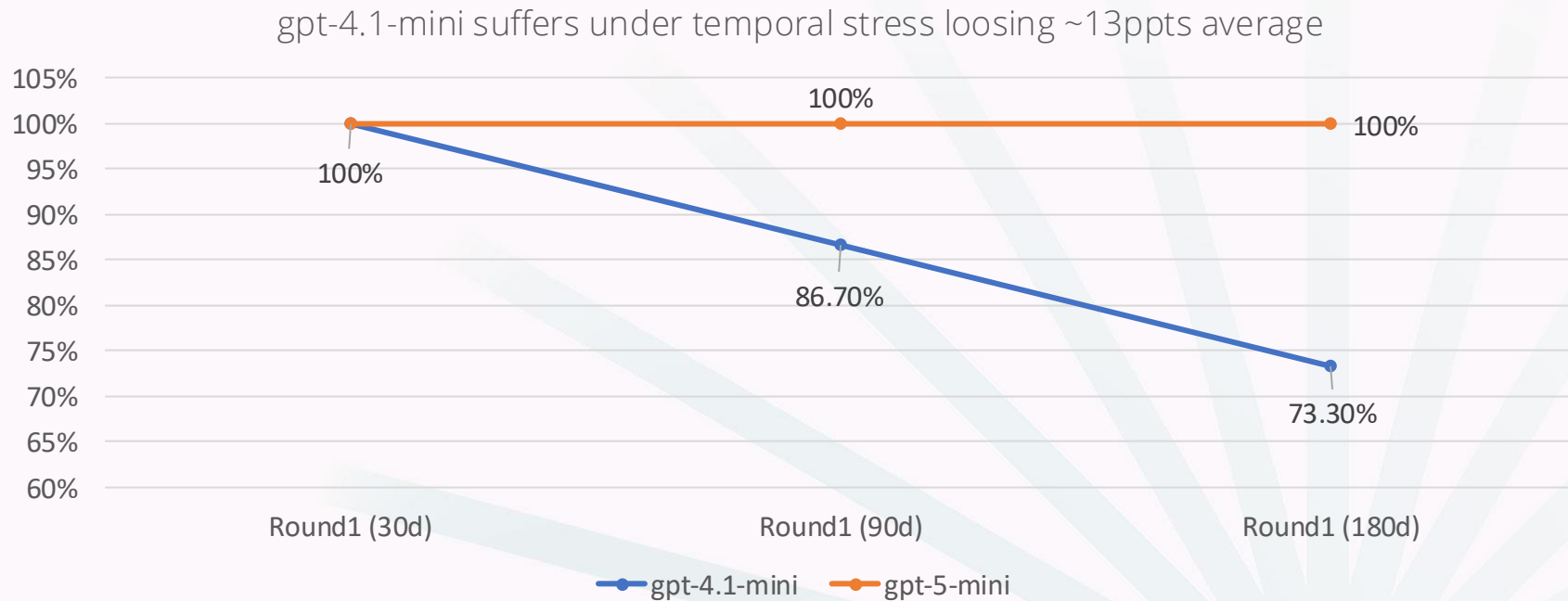
So, In a real SOC, detection is just the starting point — L2 investigates and contains. The question shifts from 'does it work?' to 'what trade-off do you accept?'

Global Label Accuracy by round

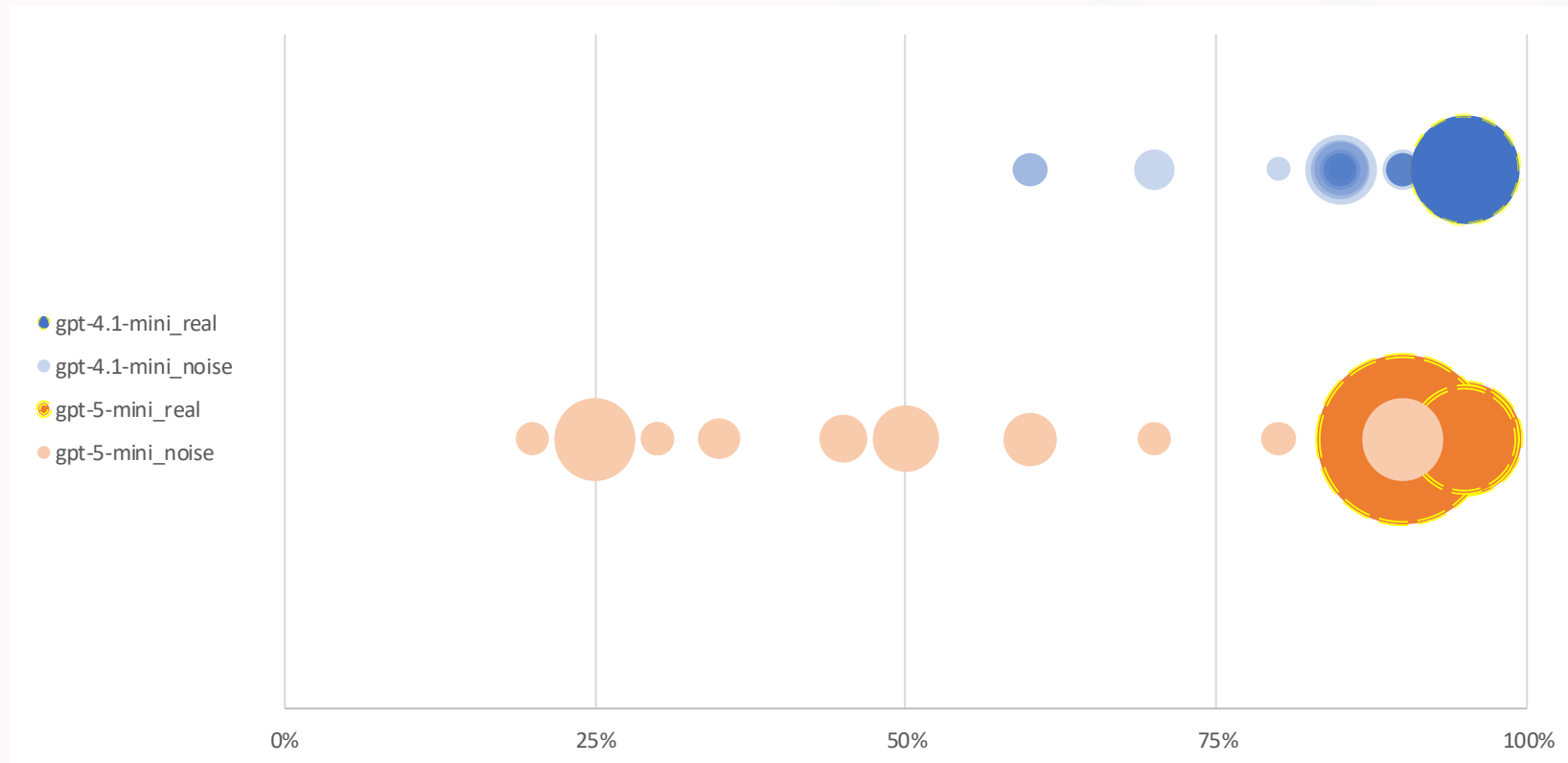
Temporal stress



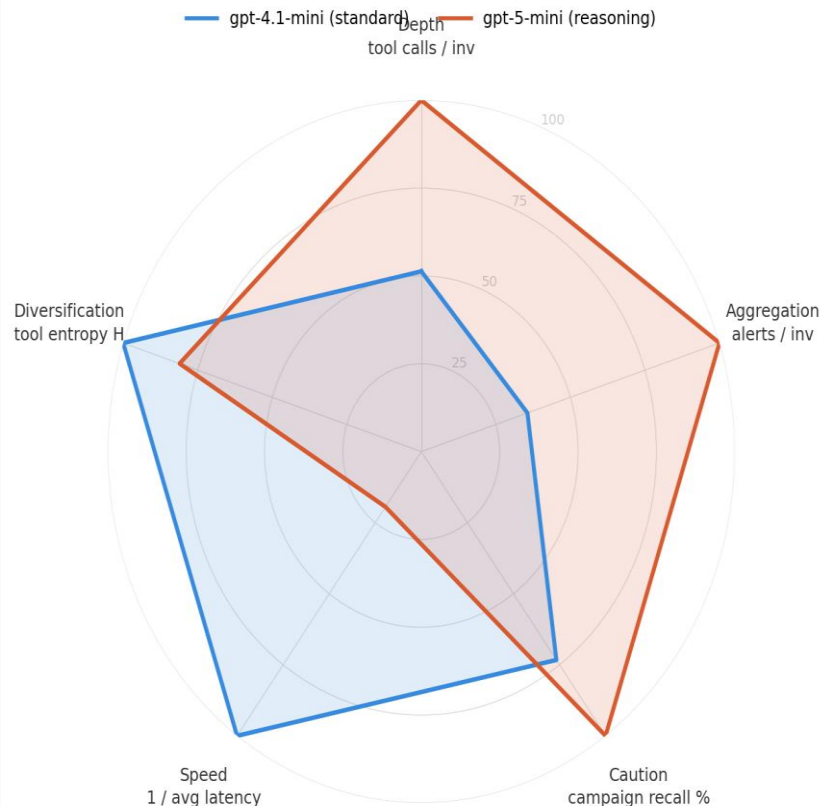
Campaign recall – efficacy to find the real threats.



Confidence level reported by agent per campaign



"Cognitive" behavior



BEHAVIORAL DIMENSIONS — avg 3 rounds, normalized 0-100

	gpt-4.1-mini	gpt-5-mini
Investigation style	breadth-first	depth-first
Alerts / investigation	2.1	5.9
Tool calls / investigation	11.8	23.0
Avg time / investigation	34s	174s
Tool entropy (H)	H = 3.17	H = 2.57
Stance (camp / FP ratio)	0.81 balanced	2.18 aggressive
Campaign recall (R3)	73.3%	100%

Cost and latency

3 rounds × 2 models · latency from local execution logs · cost from LangSmith (rounds 1–3)

gpt-4.1-mini — standard model

avg time / investigation

42s

range 38–47s

avg total run time

33 min

~47 inv avg

gpt-5-mini — reasoning model

avg time / investigation

196s

range 171–229s

avg total run time

56 min

~17 inv avg

Latency per investigation



4.7× slower per investigation

Cost per run (USD)



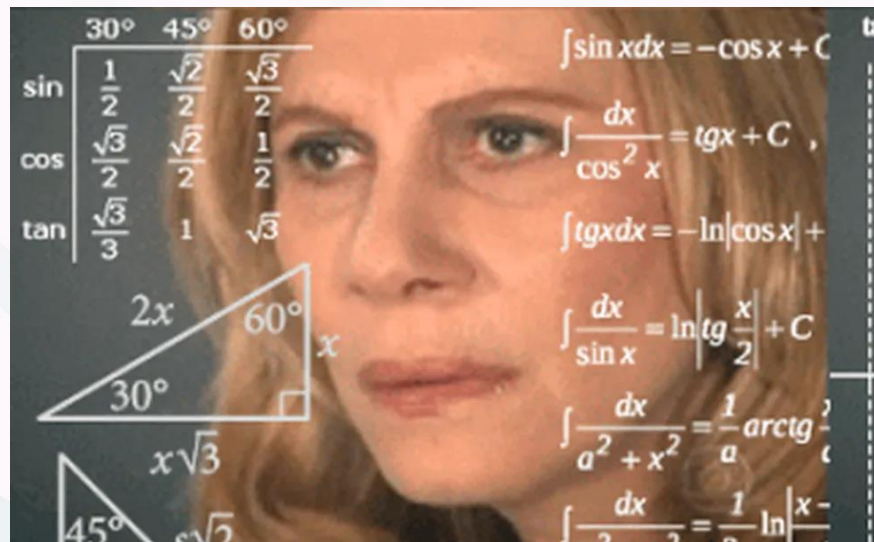
+46% cost · reasoning tokens

aaaaaaaaaaaaaaaa



CWTS

COST WEIGHTED TRIAGE
SCORE. How hurtful is a false
negative?



Accuracy hides two structural problems

01

CLASS IMBALANCE

Accuracy rewards the lazy classifier.

In a real SOC, noise dominates. An agent that always predicts "false_positive" scores ~99% without any cognitive work. Bayes shows that PPV depends on the base rate, not on TPR.

Axelsson (2000) — The Base-Rate Fallacy and the Difficulty of Intrusion Detection Systems

02

COST ASYMMETRY

FN and FP do not cost the same. Accuracy treats them as 1:1.

FP costs analyst hours. FN lets a threat slip through dwell time, completed incident. The literature suggests ratios of 10:1 to 100:1.

Elkan (2001) • Stolfo et al. (2000) • Gaffney & Ulvila (2001)

▼ **CWTS addresses both — normalization covers (1), weight k covers (2)**

CWTS – assymetric cost turns into score

Illustration of the SOC asymmetric cost calculation.

THE INTUITION:

Each FP costs **1 point**.

Each FN costs **50 points**.

The winner has the **lowest total cost**.

"The k=50 is not mine — it is the midpoint of the documented range by Gaffney & Ulvila 24 years ago. They brought decision theory to IDS in 2001. I am applying their framework to AI agents — not inventing anything, just extending."

EXAMPLE APPLIED TO ROUND 3:

$$\text{gpt-4.1-mini} = 18\text{FP} \times 1 + 8\text{FN} \times 50 = \mathbf{418}$$

$$\text{gpt-5-mini} = 35\text{FP} \times 1 + 0\text{FN} \times 50 = \mathbf{35}$$

$$\text{Worst case} = 70\text{FP} \times 1 + 30\text{FN} \times 50 = \mathbf{1570}$$

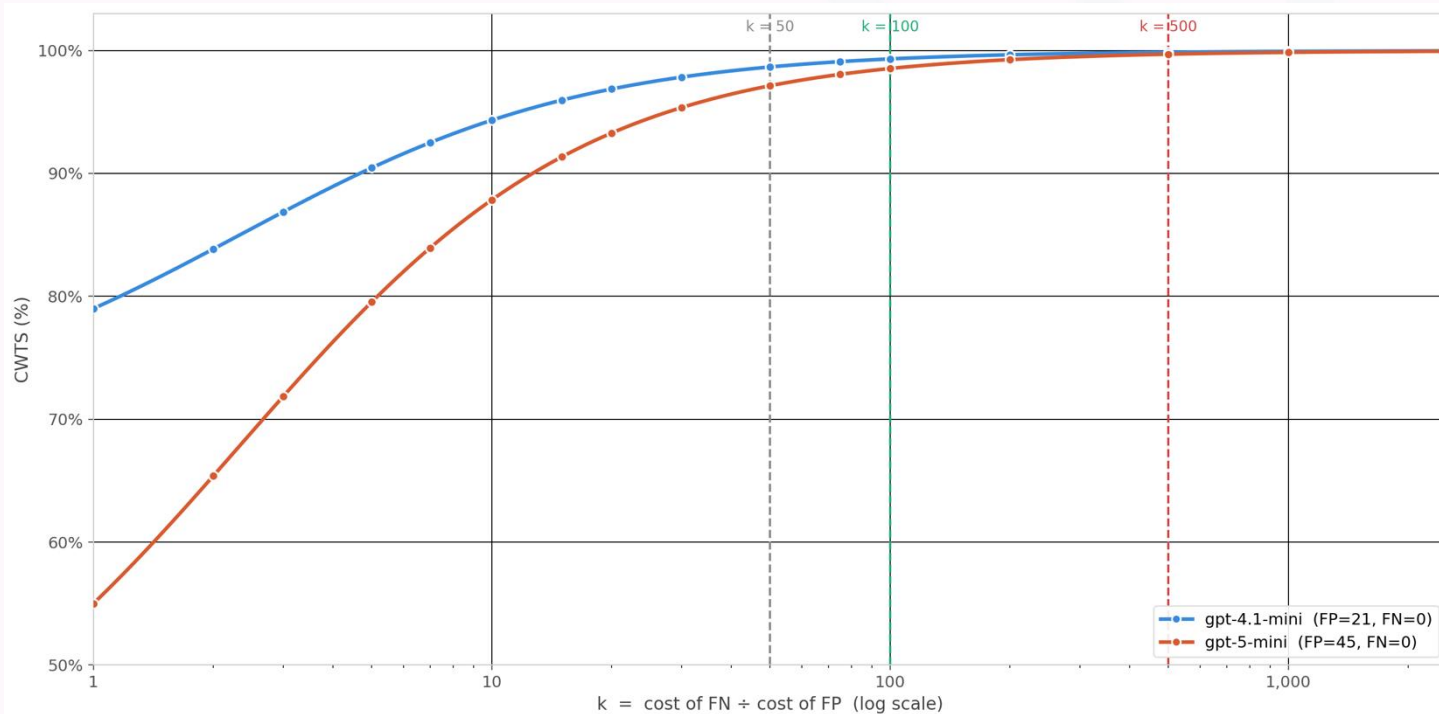
$$\text{CWTS} = 1 - \text{round_cost} / \text{worst_case}$$

$$4.1\text{-mini} \rightarrow \mathbf{73,4\%} \qquad 5\text{-mini} \rightarrow \mathbf{97,8\%}$$

Elkan (2001) · Stolfo, Fan, Lee et al. (2000) · Gaffney & Ulvila (2001)

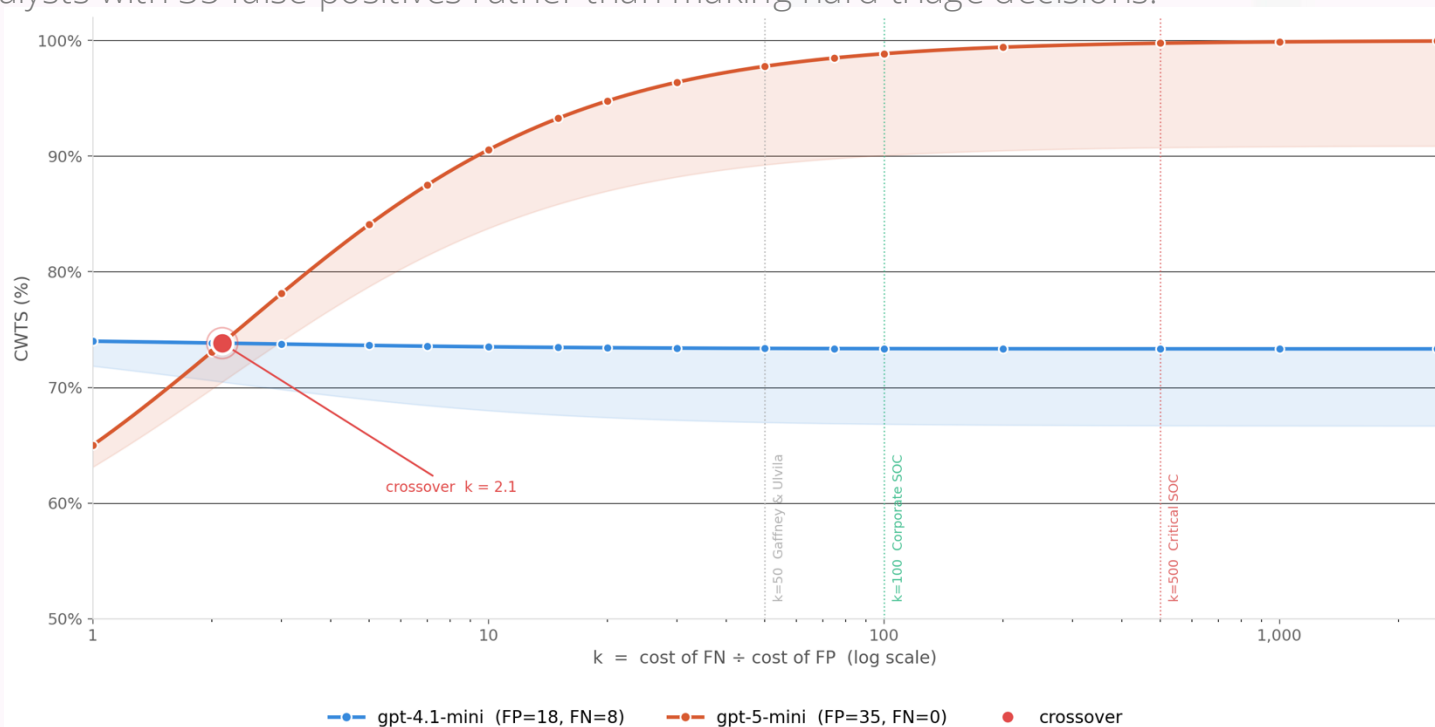
CWTS Curve – round 1 (30 days)

Looks easy to the agent. Both models achieved 100% Campaign recall, gpt-4.1 looks better because less over-aggregation.



CWTS Curve – round 3 (180 days)

Gpt-5-mini's perfect recall wins at any realistic SOC cost ratio ($k > 2.1$), but only because it never commits flooding analysts with 35 false positives rather than making hard triage decisions.



Closing

Research insights, risks of adoption and few takeaways.



Lessons learned from research

01 **AUGMENTED TRIAGE WORKS**

Tier-1 agent built with LangGraph + typed tools + observability delivers measurable results. 6 runs, 600 alerts with accuracy above >70% sustained across 3 rounds, plus CWTS greater than 90% for K=50. All malicious campaigns were detected.

02 **DIFFERENT MODELS, THERE IS NO ONE WINNER**

Switching from gpt-4.1-mini to gpt-5-mini changed the cognitive style. Reasoning models work fundamentally differently — model choice is a choice of operational bias.

03 **REASONING MODEL REPORTS CALIBRATED CONFIDENCE, STANDARD DOES NOT**

gpt-5-mini distributed confidence into two bimodal clusters — it knows when to doubt what it produces. gpt-4.1-mini reports a flat confidence (85%–95%), which can be a challenge for tier-2 prioritization.

04 **AGENT RELIABILITY COMES FROM ENGINEERING, NOT FROM THE MODEL**

Pre-tuning of typed tools (Pydantic), pre-loading decisions into the prompt, rigorous observability (LangSmith), deterministic ground truth. +9 pp of accuracy came from this phase alone, before any benchmark. Cost: \$15. Engineering > prompt engineering.

05 **METRICS MUST RESPECT THE SOC ASYMMETRY**

Accuracy treats FP and FN as equal. A real SOC does not — missing a threat costs 50× more than investigating noise. CWTS gives a mathematical vocabulary for this asymmetry.

Risk of adoption

PRODUCTIVE VARIANCE

Agent quality depends on fine-tuning, embeddings, prompts, and real data quality. A synthetic benchmark is a theoretical floor, not a guarantee.

Remember: GIGO – Garbage in, Garbage out.

PIPELINE COMPLEXITY

Your SOC's pipeline complexity will grow. Who will review the agent's output? How will keep finetuning of the agents? What kind of guardrails will be defined? How to measure what improved or worsened? It is essential to have active AI engineering in the team.

CONFIRMATION BIAS

We saw that standard models report high confidence in almost all results, with a coherent narrative — analysts may fall into confirmation bias. Using models that output distributed confidence can help enable a more cautious analysis.

“It is not the agent getting it right too much that should operate alone. Where it makes mistakes is exactly what the human covers.”

Augmented, not autonomous.

✓ **LESS RISK**

Human validates output.

- Automatic documentation of alerts (description, context, MITRE mapping)
- Enrichment (IOC lookups, geo, ATT&CK tactic, threat intel)
- Correlation deterministic (same hash, same URL, same IP)
- Summarization of long cases for handover between shifts

⚠ **CAUTION AND SUPERVISION**

Senior human validates each decision.

- Full autonomous L1 triage (action-reason desync, over-aggregation)
- Final FP / escalation decision without human review
- Automated incident response (containment, isolation)
- Multi-agent autonomous without observability between steps



ENGINEERING DISCIPLINE — NON-NEGOTIABLE

- Observability end-to-end (traces, metrics, etc)
- Versioning of prompts and schemas
- Periodic audit of decision quality (hallucinations, drift)
- Continuous monitoring (purity, recall, latency, cost)

Thank you!

Rômulo Rocha

linkedin.com/in/romrocha

github.com/romrocha

